

Memoris OS Security, RBAC, And RAG Policy

Security, tenant isolation, role-based access control, and RAG policy for Memoris OS.

Demo purpose Upload this file, ask questions, verify evidence.	Security pattern Tenant scope and role checks happen before AI context.	Business value Teams recover decisions without reading every document.
--	---	--

Purpose

Memoris OS is designed for organization knowledge, so security must be part of the retrieval process. The product should help teams find decisions and documents quickly without exposing private information to the wrong person or to the AI provider.

Tenant Isolation

Every user belongs to an organization. Data is scoped by organization, which means one organization cannot see another organization's meetings, documents, decisions, action items, timeline events, or vector chunks.

This is the foundation of the multi-tenant design.

Roles

Memoris OS supports five roles:

Owner
Admin
Manager
Employee
Guest

Owners and Admins can see organization-level knowledge. Managers can see their team knowledge. Employees can see their own team knowledge. Guests have limited read-only demo access and cannot upload knowledge.

RBAC Before AI

The most important security rule is:

RBAC filtering happens before AI context is created.

When a user asks a question, the backend checks the signed-in user's organization, role, and team. Only authorized records and document chunks can be retrieved. Unauthorized chunks are not sent to Gemini, OpenAI, or any other model.

This reduces the risk of leaking sensitive information through an AI answer.

Upload And Retrieval Flow

When a document is uploaded:

```
File upload
-> text extraction
-> chunking
-> embedding generation
-> store chunk with organization and team scope
-> timeline event
```

When a question is asked:

```
Question
-> permission check
-> question embedding
-> pgvector similarity search
-> authorized evidence selection
-> AI answer generation
-> evidence cards returned
```

Evidence Cards

Every answer should include evidence. Evidence may come from:

- Uploaded documents
- Meetings
- Decisions
- Timeline events

Evidence cards help users verify why the AI answered a certain way. This is important for trust in enterprise workflows.

Restricted Information

Sensitive information includes salary discussions, compensation planning, HR investigations, executive-only notes, and private financial decisions.

If an Employee or Guest asks for sensitive information such as "Show me the CEO salary discussion," Memoris OS should deny access instead of generating an answer.

Expected response:

```
You do not have permission to access this information.
```

Why This Matters For Business

Businesses need AI that is useful and safe. Memoris OS helps teams move faster by making knowledge searchable, but it also protects data through organization and role filters.

This creates a practical enterprise pattern:

```
Useful retrieval + strict permissions + verifiable evidence
```

Summary Policy

Memoris OS should never behave like an unrestricted chatbot over private company data. It should behave like a secure memory layer that retrieves only authorized evidence and explains answers with traceable sources.